Program Reference Guide — Terms, Tiering, Templates and Samples

Oct 24, 2026 · @Manas

Companion to the Security Hardening Assessment Program charter (v0.6). Samples use placeholder data and are illustrative only; they are not findings.

Key terms explained

Eight terms in the charter carry specific obligations or methods. The table says what each one is and where the program uses it.

Term	What it is	How the program uses it
IR (incident response)	The capability to prepare for, detect, contain, eradicate and recover from security incidents, then learn from them. NIST SP 800-61 Rev 3 (April 2025) replaced the 2012 lifecycle model and now aligns IR with the CSF 2.0 functions (Govern, Identify, Protect, Detect, Respond, Recover).	WS1 reviews the IR plan, roles, severity model, regulatory reporting and the playbooks. WS2, WS3 and WS5 supply the layer playbooks (container escape, credential compromise, key compromise, contract exploit). The output is an IR maturity rating plus playbook gaps.

Term	What it is	How the program uses it
NYDFS Part 500	The New York Department of Financial Services cybersecurity regulation (23 NYCRR 500), amended in November 2023. It applies to entities licensed by NYDFS, for example a BitLicense or trust charter. Key obligations: • notice to the Superintendent within 72 hours of determining a cybersecurity incident has occurred; • notice within 24 hours of an extortion payment, with a written explanation within 30 days; • an annual compliance certification by April 15, signed by the CEO and CISO; • MFA for all access and a documented asset inventory, both required since November 1, 2025; • IR and BCDR plans that are tested.	Applies only if Legal confirms a NYDFS license. If it does, the crosswalk maps Part 500 sections, WS1 checks the 72-hour and 24-hour notification paths and the certification evidence, and WS3 checks MFA coverage against 500.12.
BCP (business continuity plan)	How the business keeps critical services running during and after a disruption. It is built on a business impact analysis, with a recovery time objective (RTO, how fast) and a recovery point objective (RPO, how much data loss is acceptable) for each service. DR (disaster recovery) is the technical restore part. ISO 22301 is the reference standard; DORA Art. 11–12 and NYDFS 500.16 require plans that are tested.	WS1 reviews the BCP and DR plans. WS4 runs a sampled restore test (AWS Backup with Vault Lock, cross-region copies). WS5 checks key recovery: can signing keys and multisig quorum be recovered without weakening the threshold?

Term	What it is	How the program uses it
IRSA	IAM Roles for Service Accounts. An EKS pod gets AWS permissions by assuming an IAM role through the cluster's OIDC identity provider, instead of using the node's instance role. EKS Pod Identity is the newer alternative: it uses an agent instead of a per-cluster OIDC provider.	WS2 and WS3 check that pods use IRSA or Pod Identity with least-privilege roles and that role trust policies are scoped to one namespace and service account. They also check that IMDS hop limit 1 stops pods from reaching node credentials.
ASVS 5.0	The OWASP Application Security Verification Standard, version 5.0, released May 2025. It is a catalogue of testable application security requirements at three levels (L1 baseline, L2 standard, L3 high assurance), and adds chapters for self-contained tokens, OAuth/OIDC and WebRTC.	WS4 tests Tier 1 apps (the B2C login-to-withdrawal path, admin consoles, top APIs) at L2, and at L3 for authentication and authorization on money-moving flows. Other apps get tool-based checks.
SLSA	Supply-chain Levels for Software Artifacts. Its Build track runs from L0 (nothing) through: • L1: provenance exists; • L2: signed provenance from a hosted build platform; • L3: a hardened, tamper-resistant build platform. v1.2 is the current spec.	WS4 rates each pipeline's SLSA Build level, with a target of L2 now and L3 for contract and production deploy pipelines. It checks provenance verification at deploy and admission time.
SAMM	OWASP Software Assurance Maturity Model v2: 5 business functions (Governance, Design, Implementation, Verification, Operations), 15 practices, and maturity levels 1–3.	WS4 scores SDLC maturity per practice (for example Threat Assessment, Security Testing, Secure Build) to show where the program's recommendations raise maturity.

Term	What it is	How the program uses it
Anchor checks	Anchor is the main Solana framework. Its account constraints check signers (`Signer`), owners and account types (`Account<T>` with discriminators), PDA seeds and bumps, `has_one` relationships, and safe `init` and `close`.	WS5 reviews every instruction for missing signer, owner, PDA or `has_one` constraints, arbitrary CPI targets, reinitialization, duplicate mutable accounts and unchecked arithmetic. It uses `anchor test`, Trident fuzzing and `cargo audit`.

DORA's incident timelines sit alongside NYDFS when DORA applies: initial notification within 4 hours of classifying an incident as major (24 hours at most from awareness), an intermediate report within 72 hours, and a final report within one month.

Crown jewels

A crown jewel is an asset whose compromise alone could cause material, hard-to-reverse harm: loss of customer or treasury funds, loss of control of the platform, a reportable breach of customer data, or loss of a license. An asset qualifies if it meets **any one** of these four tests:

1. **Value:** it can move or authorize the movement of funds. On-chain transfers are final, so there is no chargeback.
2. **Control:** it grants control over many other systems, as an identity provider, management account or CI/CD does.
3. **Data:** it holds regulated customer data in bulk (PII, KYC records).
4. **Trust:** its compromise would break customer or regulator trust on its own (signing UI, front end, DNS).

Crown jewel	Test met	Primary workstream
Signing keys and Vault root, unseal and recovery material	Value, Control	WS5, WS2
Admin and upgrade multisigs, timelocks, treasury contracts	Value	WS5
AWS management account and delegated-admin security accounts	Control	WS4

Crown jewel	Test met	Primary workstream
Entra Global Admin and privileged roles; the Entra-to-Identity Center trust	Control	WS3
B2C customer login-to-withdrawal path	Value, Data	WS3, WS4
CI/CD deploy path to production and to contracts	Control, Value	WS4, WS5
Customer PII and KYC stores (Aurora, S3)	Data	WS4
dApp front end, DNS and registrar	Trust, Value	WS4

WS1 confirms this list with owners in week 2, adds any it missed (for example an oracle the company operates), and gives each crown jewel a named owner. Every crown jewel is Tier 1 by definition.

Tiering: Tier 1, 2 and 3

Tiers decide assessment depth and order. They are set by how close an asset sits to a crown jewel, not by how important its owning team is. WS1 assigns tiers in week 1 from the reconciled inventory and revises them whenever attack-path analysis finds a new path.

Tier	Assign when the asset…	Examples here	Assessment depth
Tier 1	is a crown jewel; **or** can reach one in two steps or fewer (holds credentials for it, has network or API access to it, or deploys code to it); **or** is an internet-facing entry point on such a path	Vault and signer hosts; admin multisigs; management account; Entra privileged roles; B2C withdrawal APIs; contract deploy pipeline; EKS clusters that run signing or withdrawal services	Tool-based checks plus full manual review on 100% of assets, weeks 3–7; attack paths validated end to end
Tier 2	is production and handles customer data or business-critical services, but sits on no crown-jewel path; **or** is a shared security service (logging, SIEM, backup)	Marketing and analytics workloads; internal APIs without fund access; OpenSearch; Splunk forwarders; Backup vaults	Tool-based checks on 100%, plus a manual sample of at least 25% (at least 3 per class), weeks 10–12

Tier	Assign when the asset…	Examples here	Assessment depth
Tier 3	is non-production or internal tooling with no production credentials, data or network path	Dev and test accounts with no prod trust; sandboxes; build caches	Tool-based checks on 100%, plus a manual sample of at least 25% (at least 3 per class), weeks 10–12

Decision order (the first rule that matches wins):

1. A crown jewel is Tier 1.
2. A path to a crown jewel in two steps or fewer makes the asset Tier 1. Use graph evidence (PMapper or Cartography, Access Analyzer, security-group reachability), not opinion.
3. Non-production holding production credentials, keys, data or trust inherits the tier of the production asset it can reach.
4. Production with regulated data, or a shared security service, is Tier 2.
5. Everything else is Tier 3.
6. When in doubt, tier up and record why. The steering group can tier down with a written rationale.

Crown jewels vs Tier 1: keeping them distinct

The two terms answer different questions. **A crown jewel is what we protect**: an impact label. **Tier 1 is what we assess first and in full depth**: a scope label. Every crown jewel is Tier 1, but Tier 1 also includes assets that are not crown jewels yet can reach one in two steps or fewer. A CI runner that can deploy to the treasury contract is an example. "Tier 1 apps" therefore means applications that are crown jewels **or** sit on a path to one.

Earlier material sometimes mixed the two terms. The steering group chose **option A**, and the charter (v0.6), the deck and this guide now follow it. Options B and C are kept below for the record.

Option	How it works	Pros	Cons	Changes needed
A. Two terms, strict usage (adopted)	Keep both terms. Use "crown jewel" only for impact: targets, attack scenarios, rating. Use "Tier 1" only for scope: depth, order, sampling, KPIs.	Least change; keeps the executive-friendly phrase "crown jewels"; the rating model and attack scenarios already use it	People must learn the rule; needs a one-line definition wherever both appear	Done: the slide boxes are renamed "Crown jewels and Tier 1 paths" and list both separately; the charter's sampling rule defines Tier 1 by the decision order; the charter's WS1 section and the WS1 slide state the rule
B. One scale: Tier 0–3	Crown jewels become **Tier 0**; Tier 1 = two steps or fewer from Tier 0; Tiers 2 and 3 as now. "Crown jewel" becomes an informal alias for Tier 0.	One scale everywhere; simple to filter in the register; familiar to identity teams	"Tier 0" already means the identity control plane in Microsoft's enterprise access model, so Entra teams may read it narrowly; every tier reference must be renumbered	Renumber the charter, deck, KPIs, sampling rule and register; Tier 0 and Tier 1 both get full depth

Option	How it works	Pros	Cons	Changes needed
C. Two attributes	Every asset gets a **criticality** (crown jewel / high / standard) and an **exposure** (steps to a crown jewel, internet-facing or not). The tier is derived from a small matrix.	Most precise; matches the business impact analysis and the rating model	Hardest for executives; more fields to maintain in the inventory	Add two inventory fields and a derivation table; rewrite the tiering section

Usage rule (adopted): say "crown jewel" when you mean *the thing an attacker wants*, and "Tier 1" when you mean *the things we look at first*.

Rating model

Every finding gets one rating (Critical, High, Medium or Low) from two inputs: **proximity**, how close the weakness is to a crown jewel, and **impact**, what happens if it is exploited. CVSS v4.0 is recorded for technical findings and feeds the exploitability modifier, but it does not set the rating on its own. One model applies to every workstream, so findings from Amazon Linux 2023, Entra ID and a Solidity contract can be ranked against each other.

Proximity (P), measured with attack-path evidence

Level	Meaning
P4	The weakness is in a crown jewel itself (0 steps)
P3	One step from a crown jewel
P2	Two steps from a crown jewel
P1	Three or more steps, or no validated path

Impact (I)

Level	Meaning (any one applies)
I4 Severe	Funds at risk above [$ threshold]; loss of control of the platform, keys or contracts; a breach that must be reported (NYDFS, DORA, GDPR)
I3 Major	Funds at risk between [$ thresholds]; privileged access to production; bulk customer data exposed
I2 Moderate	Limited data or service impact; needs another weakness to cause harm
I1 Minor	Hygiene issue with no direct harm

Value at risk, meaning the funds an attacker could move, is the impact measure for blockchain findings. The CISO and finance set the [$] thresholds at gate 1.

Rating matrix

Impact \ Proximity	P4	P3	P2	P1
I4 Severe	Critical	Critical	High	Medium
I3 Major	Critical	High	High	Medium
I2 Moderate	High	Medium	Medium	Low
I1 Minor	Medium	Low	Low	Low

Modifiers (applied once and recorded with a reason)

- **Up one level:** internet-facing and reachable without authentication; a known exploited vulnerability (e.g. listed in CISA KEV); a working exploit was shown during testing; or a CVSS v4.0 base score of 9.0 or higher with public exploit code.
- **Down one level:** a compensating control was validated by test, not just documented. Never below Low.
- A finding tied to a regulatory requirement is flagged as **Regulatory**. Its owner can accept it or defer it, but not reject it.

What each rating triggers

Rating	Escalation	Roadmap slot
Critical	Owner, CISO and SOC within 24 hours; containment retested by the program within 7 days	Now (0–30 days)
High	Reported weekly at steering	Now or Next (⩽ 90 days)
Medium	Gate reviews	Next (30–90 days)
Low	Final report	Later (90+ days)

Crosswalk register template

The crosswalk is a workbook with three linked sheets: requirements (one row per requirement in each standard), unified controls (one row per control the program tests), and links (one row per control-to-requirement pair). It extends the project's existing registers, keeping their column conventions and Duplicate/Related flags.

Sheet 1 — Requirements catalogue

Column	Content
Req ID	Native ID, e.g. `IA-2(1)`, `A.8.5`, `6.5`, `500.12`, `req-verify-privileged-access`
Standard, version	e.g. NIST SP 800-53 Rev 5; ISO/IEC 27001:2022
Section	Family, clause or domain
Paraphrase	Short paraphrase; never licensed text

Column	Content
Requirement level	MUST / SHOULD; CIS Level 1/2 or IG1–3; 800-53 baseline
Applicable	Yes / No, with the reason (e.g. "PCI: no cardholder data")
Coverage result	Full / Partial / Fail / Not assessed, rolled up from the links

Sheet 2 — Unified controls

Column	Content
UC ID	e.g. `UC-IAM-001`; blockchain rows keep their `UCR-` IDs
Control statement	One testable sentence
Workstream, owner	WS2–WS5; system owner
Tier scope	Tier 1 / 2 / 3
Test procedure	Steps, or a native check ID (CIS, FSBP, kube-bench)
Evidence	Tool output, screenshot or export reference in the Restricted repository
Result	Pass / Fail / Partial / Not tested, with a finding ID if failed

Sheet 3 — Links

Column	Content
UC ID → Req ID	One pair per row
Relationship (NIST IR 8477)	Equal / Subset of / Superset of / Intersects with / No relationship (read as "the control is ___ the requirement")
Link source	Published mapping (name it) or judgement
Status	Candidate / Reviewed (reviewer, date)

Column	Content
Credit	Full (equal, superset) / Partial (subset, intersects)

Sample: one unified control linked across seven standards (illustrative)

`UC-IAM-001` — *Phishing-resistant MFA is required for all privileged human access to Entra, Identity Center and Vault.*

Requirement	Relationship	Credit	Why
CSF 2.0 PR.AA-03	Subset of	Partial	The CSF outcome covers all authentication, not only privileged
800-53 IA-2(1)	Superset of	Full	IA-2(1) requires MFA for privileged accounts; the control adds phishing resistance
ISO 27001 A.8.5	Subset of	Partial	A.8.5 covers secure authentication generally
CIS Controls v8.1 6.5	Superset of	Full	6.5 requires MFA for administrative access
BSSC GSP req-verify-privileged-access	Equal	Full	Same intent: step-up, phishing-resistant MFA for admins
NYDFS 500.12	Subset of	Partial	500.12 requires MFA for all access, not only privileged
PCI DSS 4.0.1 8.4.1	Superset of	Full (if in scope)	8.4.1 requires MFA for administrative access into the CDE

Rules

- Link a unified control directly to each requirement. Never infer a link through CSF or ISO.
- Links taken from published mappings start as candidates and support no claim until reviewed.
- A failed control fails every requirement where it carries full credit. Where it carries partial credit, the requirement shows as "partially assessed".

- A requirement with no linked control is reported as "Not assessed", never as a pass.

Standards cross-check report template

The report (week 14) answers three questions for each standard: how much did we assess, how much passed, and where do the standards disagree or leave gaps? It is an internal readiness view, not a certification or attestation opinion.

Outline

1. **Summary:** one paragraph per standard, with headline coverage and conformance figures and the three most significant gaps.
2. **Method:** hub and links, relationship types, credit rules, review sampling, and the versions pinned.
3. **Coverage matrix:** one row per standard (below).
4. **Per-standard views:** families or domains, with Full / Partial / Fail / Not assessed counts and the top failing requirements, each linked to a finding ID.
5. **Stricter-than and conflict log:** where standards differ, and the requirement adopted.
6. **Gap log:** risks no standard covers well, and the program-specific controls added for them.
7. **Not assessed:** requirements no test reached, with the reason and a proposed owner.
8. **Appendices:** the link register extract, reviewer sign-offs and evidence index.

Coverage matrix (figures filled in at week 13; placeholders shown)

Standard	In scope	Assessed	Full	Partial	Fail	Not assessed
NIST CSF 2.0 (subcategories)	[n]	[n]	[n]	[n]	[n]	[n]
NIST SP 800-53 Rev 5 (controls + enhancements)	[n]	[n]	[n]	[n]	[n]	[n]
ISO/IEC 27001:2022 (clauses + Annex A)	[n]	[n]	[n]	[n]	[n]	[n]
SOC 2 TSC	[n]	[n]	[n]	[n]	[n]	[n]
CIS Controls v8.1 / Benchmarks	[n]	[n]	[n]	[n]	[n]	[n]
BSSC (NOS, TIS, KMS, SCS, GSP)	[n]	[n]	[n]	[n]	[n]	[n]
PCI DSS 4.0.1 (if in scope)	[n]	[n]	[n]	[n]	[n]	[n]
DORA / MiCA / NYDFS (if applicable)	[n]	[n]	[n]	[n]	[n]	[n]

Conflict log (sample row)

ID	Topic	Requirements	Type	Adopted requirement	Decided by
CF-001	Security log retention	BSSC NOS req-retain-logs (180 days); PCI DSS 10.5.1 (12 months, 3 months immediately available); NYDFS 500.6 (audit trails 3 years)	Stricter-than	Keep the longest applicable period per log class, after Legal confirms which regulations apply	GRC lead; Legal

Gap log (sample row)

ID	Risk	Why the standards fall short	Program control
GP-001	Missing signer or owner checks in Solana programs	Covered only generically by SCSVS and BSSC SCS	`UC-SOL-001`: every instruction enforces signer, owner, PDA and `has_one` constraints, verified by review and Trident fuzzing

Handover pack

The handover pack is the set of artifacts, owners and decisions that lets the organization carry on without the program team. It is delivered in week 16 and accepted at gate 4. Without it, the findings stall once the assessors' access is removed.

Item	Content	Receiving owner
Final report set	Executive report, workstream reports, risk heat map, residual-risk statement, readiness view per standard	CISO

Item	Content	Receiving owner
Unified findings and control register	Every finding with its rating, evidence link, unified control and requirement links; marked read-only at handover, then maintained by GRC	GRC lead
Owner decision log	Accepted, deferred (with date) and rejected (with a CISO-approved risk acceptance) for every recommendation	GRC lead
Remediation roadmap	Now / Next / Later items with owner team, effort, dependencies and verification test	Remediation forum
Target baselines and specifications	Amazon Linux 2023 and EKS baselines, landing-zone guardrail set, identity baseline, SDLC gates, contract SDLC gates, key-custody design, target-state architecture	Platform, identity, AppSec and Web3 engineering leads
Crosswalk v3 and cross-check report	The three-sheet workbook, conflict log, gap log, "not assessed" list	GRC lead
Playbook drafts and detection inputs	Container escape, credential compromise, signing-key compromise, contract exploit; priority detections and validation results	SOC lead
KPI baselines	Posture metrics measured during the program, with definitions and data sources	Remediation forum
Remediation forum terms of reference	Chair (CISO), members, monthly cadence, exception process (90 days maximum), escalation path, first meeting date	CISO

Item	Content	Receiving owner
Re-assessment plan	Annual re-assessment scope, trigger events (new chain, major platform change, incident) and method	GRC lead
Evidence index and retention	Location of the Restricted repository, retention period, access list after week 16	GRC lead
Known limitations and open items	Requirements not assessed, tests not completed, open disputes	CISO
Access closure record	Confirmation that every assessor's access was removed, with dates	Security operations

Acceptance criteria at gate 4: every item above is delivered and has a named receiving owner; GRC confirms the register and crosswalk have been transferred; the first remediation-forum meeting is on the calendar; and the access closure record is complete.

Sample: identity assessment report (WS3)

Illustrative structure and wording. Bracketed values are placeholders and the findings are typical examples, not results.

Cover block: WS3 Identity and Access · assessment period [weeks 3–7] · classification Restricted · version [1.0] · fact-checked by [owner names, dates]

1. Executive summary An attacker who phishes one of [n] engineers with standing Entra Global Admin controls a crown jewel directly, and can reach the AWS management account in one more step through Identity Center. [n] critical and [n] high findings sit on that path. Closing the three "Now" recommendations below removes the path. Phishing-resistant MFA covers [n]% of privileged identities; the target is 100%.

2. Scope and method Scope: Entra ID tenant, Azure AD B2C tenant, IAM Identity Center, IAM in [n] accounts, workload identities (IRSA, Pod Identity, CI OIDC). Method: configuration export review, Entra and Access Analyzer reports, and graph analysis (PMapper or Cartography) of attack scenarios S1 and S4. Evidence is in the Restricted repository under [path].

3. Findings summary

ID	Finding	Rating	On crown-jewel path	Priority
IAM-F01	[n] standing Entra Global Admin assignments outside PIM; [n] without phishing-resistant MFA	Critical	Yes: Entra → Identity Center → management account	Now
IAM-F02	Identity Center AdministratorAccess permission set assigned to [n] users in all accounts, including management	High	Yes	Now
IAM-F03	CI deploy role trust policy allows any repository in the GitHub organization (`repo:org/*`)	High	Yes: CI → contract deploy	Now
IAM-F04	[n] IAM users with active access keys older than 365 days, [n] with admin policies	High	Partly	Next
IAM-F05	B2C: no MFA step-up when a withdrawal address is added; refresh tokens last [n] days	Medium	Yes: account takeover → withdrawal	Next
IAM-F06	Break-glass sign-ins raise no Splunk alert	Medium	Indirect	Next

4. Finding detail (one shown; every finding uses this format)

- **ID and title:** IAM-F01 — Standing Global Admin outside PIM
- **Rating:** Critical (P4: Entra Global Admin is itself a crown jewel × I4: loss of control of the tenant and, through Identity Center, of AWS)
- **Evidence:** Entra role-assignment export [file], dated [date]; sign-in logs showing [n] assignees authenticating with SMS or app push
- **Unified control and standards:** UC-IAM-001 and UC-IAM-004 → CSF 2.0 PR.AA-05 · 800-53 AC-6(5), IA-2(1) · ISO 27001 A.8.2, A.8.5 · CIS 5.4, 6.5 · BSSC GSP req-verify-privileged-access · NYDFS 500.7, 500.12 (if applicable)

- **Recommendation:** Move all Global Admin assignments to PIM eligible-only with approval and a 4-hour maximum. Enforce a Conditional Access authentication strength of phishing-resistant MFA for every directory role. Keep two monitored break-glass accounts that use FIDO2 keys.
- **Owner, effort:** Identity platform team · S
- **Verification test:** The role-assignment export shows 0 active standing Global Admins outside break-glass; the CA policy report shows the phishing-resistant strength applied to all directory roles; a test sign-in with app push is refused.
- **Owner fact-check:** [Confirmed / Disputed + note] · [date]

5. Target identity baseline: summary of the WS3 baseline and the gap against it.

6. Appendices: privileged-access map, scenario path graphs, evidence index.

Entra External ID migration plan (WS3)

Why it is in the WS3 baseline

- Microsoft stopped selling Azure AD B2C to new customers on May 1, 2025. Existing tenants are supported until at least May 2030.
- The B2C P2 tier was discontinued for all customers on March 15, 2026. Any risk-based sign-in protection that depended on P2 needs checking for a replacement.
- Microsoft Entra External ID is the successor product.
- The customer login-to-withdrawal path is a crown jewel. Leaving it on a product that is no longer sold limits future security features.

The program **recommends and outlines** the migration. The identity team plans in detail and executes after handover.

What the WS3 migration plan contains

1. **Inventory:**
    - applications and redirect URIs;
    - user flows and custom policies;
    - social and enterprise identity providers;
    - API connectors and REST calls;
    - claims and token settings that downstream APIs rely on;
    - custom domains, MFA methods and branding;
    - user count, credential types, and logging into Splunk.

2. **Gap analysis:**
    - B2C custom policies have no direct equivalent. Their logic must be redesigned with External ID user flows and custom authentication extensions, and Microsoft does not guarantee one-to-one parity.
    - Some features, such as age gating, are not supported.
    - Conditional Access, step-up MFA and fraud protection need equivalents.
3. **Target design:**
    - an External ID (external) tenant, user flows, custom authentication extensions and a custom domain;
    - Conditional Access for sign-in, plus app-triggered re-authentication with MFA on withdrawals and address changes;
    - a web application firewall in front of the sign-in endpoints;
    - logs into Splunk.
4. **User migration approach**, from Microsoft's documented options:
    - **Bulk migration, then cutover:** move users through Microsoft Graph, then switch the apps.
    - **Bulk migration with just-in-time password migration:** at a user's first sign-in, External ID checks the password against B2C through a custom authentication extension, then stores it. This avoids forcing password resets. It is the likely recommendation for this estate.
    - **B2C-initiated migration:** passwords move in the background while the apps stay on B2C, then the apps switch.
    - **A coexistence mode for very large tenants** (around 5 million or more directory objects). It has significant limits, for example no social identity providers and no passkeys.
5. **App cutover order:** low-risk apps first and the withdrawal path last, once MFA step-up parity has been tested. Update token issuer and audience validation in every API, and include a rollback plan.
6. **Security controls during migration:**
    - Rate-limit and protect the password-validation API against brute force.
    - Monitor both tenants for account-takeover signals during coexistence.
    - Never weaken MFA during the transition.
    - Decommission the B2C tenant and its app registrations at the end.

7. **Timeline, owners and success measures:** for example, all apps cut over, no forced mass password resets, and no rise in account-takeover rates.

Microsoft's migration guidance changed during 2026. Re-check feature support against it when the detailed plan is written.

Sample: privileged-access map (WS3 with WS2, WS4, WS5)

The privileged-access map lists every identity or role that can control a crown jewel, how it gets there, and what protects it. Its source of truth is a graph export (PMapper or Cartography plus Entra exports). The table below is the reviewer view. *Placeholder counts; the rows are the roles that typically appear in this estate.*

Privileged role	Holders	Reaches	Steps to crown jewel	Controls present	Gap / finding
Entra Global Admin	[n] people, [n] break-glass	Whole tenant, Identity Center trust	0 (is a crown jewel); 1 → AWS management account	PIM [partial], MFA [mixed]	IAM-F01
Entra Privileged Role Admin	[n]	Can grant Global Admin	2	PIM	Treat as Global Admin
Identity Center admin, AdministratorAccess permission set	[n] users	All accounts, including management	1	Entra MFA	IAM-F02
AWS management account root	Centralized root access	Organization, SCPs	0 (is a crown jewel)	Root credentials removed [?], alert on use [?]	Verify
CI OIDC deploy role	[n] repositories	Production accounts; contract deployer	1 → contracts and production	OIDC, branch protection [?]	IAM-F03
EKS cluster-admin (access entries)	[n] principals	Signing and withdrawal workloads	1 → Vault tokens in pods	Access entries [?]	WS2 to confirm
Vault root token, unseal or recovery key holders	[n]	All secrets and signing keys	0	Shamir or KMS auto-unseal [?]	WS5 to confirm

Privileged role	Holders	Reaches	Steps to crown jewel	Controls present	Gap / finding
Vault admin policy	[n]	Policies, auth methods, Transit keys	1	MFA [?], audit device [?]	WS5 to confirm
Safe multisig signers (admin and upgrade)	[n]-of-[n]	Upgrades, pause, treasury	0	Hardware wallets [?], timelock [?]	WS5 to confirm
Solana program upgrade authority	[single key / multisig]	Program code	0	[?]	WS5 to confirm
B2C tenant admin	[n]	Customer authentication flows	1 → withdrawal path	PIM [?]	WS3 to confirm
Splunk admin	[n]	Detections and alerting	Indirect: can blind detection	[?]	WS4 to confirm

How to read it: "0 steps" means the role *is* crown-jewel control. Any role at 0 or 1 step must be held by named people, granted just in time where possible, protected by phishing-resistant MFA or hardware signing, and alerted on use.

Sample playbook: container escape (EKS)

Sample structure for the playbook WS2 recommends. Adapt names, times and contacts to the SOC's runbook format. The phases use the familiar SP 800-61 Rev 2 lifecycle, mapped to the CSF 2.0 Respond and Recover functions as SP 800-61 Rev 3 recommends.

Scope: a process in an EKS pod gains access to its node (host filesystem, container runtime or node credentials). MITRE ATT&CK T1611, Escape to Host.

Triggers

- GuardDuty Runtime Monitoring privilege-escalation findings on EKS, e.g. a container mounting a host directory, accessing the Docker or containerd socket, or modifying a cgroup release agent.
- CrowdStrike Falcon detection on the worker node, where the sensor is deployed.
- EKS audit log: a pod created with `privileged`, `hostPID`, `hostPath` or `hostNetwork` outside the approved exceptions.

Severity: Critical if the node runs Tier 1 workloads (signing, withdrawal, Vault agents); otherwise High.

Phase	Target time	Action	Owner
Analyze	0–15 min	Confirm the alert. Identify cluster, node, namespace, pod, image digest and service account. Check whether the node hosts Tier 1 workloads. Open an incident and name an incident commander.	SOC
Preserve	15–30 min	Before killing anything: save the pod spec, container logs and EKS audit events. Snapshot the node's EBS volumes. Collect volatile data through Falcon Real Time Response or SSM.	SOC, platform on-call
Contain	15–60 min	Label the pod for a deny-all quarantine network policy. Cordon the node. Swap the node to a quarantine security group, or use Falcon network containment.	Platform on-call
Contain: credentials	15–60 min	Treat the node role and every IRSA or Pod Identity role on the node as compromised: revoke their active sessions and rotate secrets they could read. Revoke the Vault tokens and leases of pods on the node. If a signer pod ran there, invoke the signing-key-compromise playbook and consider pausing contracts.	Security engineering, WS5 owner
Eradicate	1–24 h	Drain and terminate the node; replace it from the golden AMI. Fix the cause: privileged pod, hostPath, socket mount, or a runc or containerd CVE. Close the admission-policy gap that let it run.	Platform

Phase	Target time	Action	Owner
Recover	24–72 h	Redeploy from signed images verified at admission. Raise monitoring on the cluster for 72 hours.	Platform, SOC
Report and learn	⩽ 5 days	Root-cause analysis, regulatory classification (DORA major-incident criteria; NYDFS 72-hour notice if it qualifies), and detection and policy updates.	Incident commander, GRC, Legal

Command references (examples; validate in the runbook)

```
kubectl label pod <pod> -n <ns> quarantine=true      # matched by a deny-all NetworkPolicy
kubectl cordon <node>
aws ec2 create-snapshot --volume-id <vol-id> --description "IR-<id>"
aws ec2 modify-instance-attribute --instance-id <i-id> --groups <quarantine-sg>
vault token revoke -accessor <accessor>
vault lease revoke -prefix <secret-path>
```

Do not: delete the pod or terminate the node before evidence is captured, or leave a compromised node in an auto-scaling group that can recycle it.

Sample playbook: credential compromise

Sample structure for the playbook WS3 recommends. It covers the workforce, AWS, CI and customer credential types in this estate.

Triggers

- An Entra ID Protection risky user or risky sign-in (impossible travel, token anomaly).
- GuardDuty IAM findings, e.g. instance credentials used from outside AWS.
- AWS or GitHub secret-scanning alerts for an exposed access key.
- A CrowdStrike detection of credential theft on an endpoint.
- B2C abuse signals: new device plus a password reset plus a withdrawal-address change.

Severity: Critical if the identity appears in the privileged-access map at 0–1 steps, or if customer funds may move; High otherwise.

Key point: revoking the Entra session does not end AWS role sessions already issued through Identity Center. Those stay valid until they expire, so they must be revoked separately.

Credential type	Contain within 30–60 min	Then investigate
Entra workforce user	Revoke sign-in sessions; reset the password; remove and re-register MFA methods; disable the account if it is privileged; remove pending PIM activations	Sign-in and audit logs; OAuth app consents; mailbox rules; PIM activations during the window
AWS via Identity Center	Delete the user's active Identity Center sessions; revoke active sessions on the permission-set roles in every account they reached	Actions by the principal in CloudTrail (Splunk or CloudTrail Lake) since first suspicious use
IAM user access key	Deactivate the key; attach a deny-all policy; preserve it for the investigation, then delete	Key usage in CloudTrail; resources it created (users, keys, roles, instances)
CI OIDC role	Disable the affected workflows; narrow the trust policy to the exact repository and branch; revoke role sessions	Deployments and contract transactions during the window; artifact provenance
Vault token or AppRole	Revoke the token by accessor; rotate the secret ID; revoke the leases it issued	Vault audit log: paths read and signing calls made
B2C customer account	Lock the account; revoke refresh tokens; hold withdrawals; verify address-book changes out of band	Account and withdrawal timeline; linked accounts; whether a customer notice is needed

Phases

1. **Analyze (0–15 min):** confirm, identify the identity and its row in the privileged-access map, set severity, and name an incident commander.

2. **Contain (15–60 min):** use the table above. For privileged identities, also check for persistence: new users, keys, roles, federation trusts, app registrations, Conditional Access changes.
3. **Eradicate (1–24 h):** remove the persistence found, fix the root cause (phishing, token theft, exposed key) and re-baseline the identity.
4. **Recover (24–72 h):** restore access with phishing-resistant MFA, and raise monitoring on the identity and the resources it touched.
5. **Report and learn (within 5 days):** root-cause analysis; NYDFS 72-hour notice if a reportable incident is determined; DORA classification if applicable; customer notice if B2C data or funds were affected; detection updates.

Command references (examples; validate in the runbook)

```
# Entra (Microsoft Graph PowerShell)
Revoke-MgUserSignInSession -UserId <upn-or-id>
# AWS IAM access key
aws iam update-access-key --user-name <user> --access-key-id <AKIA...> --
status Inactive
# Vault
vault token revoke -accessor <accessor>
```

Sources

- 23 NYCRR 500.17 — Notices to Superintendent: 72-hour incident notice, 24-hour and 30-day extortion notices, April 15 certification.
- Orrick: NYDFS finalizes amended cybersecurity regulation: Class A companies, the MFA and asset-inventory deadlines (November 1, 2025), IR and BCDR plans.
- NIST SP 800-61 Rev 3: final April 2025, a CSF 2.0 Community Profile; supersedes Rev 2.
- FMA: DORA ICT-related incidents: initial notification within 4 hours of classification (24 hours at most), intermediate report within 72 hours, final report within one month.
- SLSA v1.1 security levels and SLSA current activities: Build track L0–L3; v1.2 is the current spec.
- What's new in ASVS 5.0 (SoftwareMill): first major release in six years, with rebalanced levels.
- Program charter v0.6 and the project's Unified Blockchain Control Register (UCR IDs and BSSC requirement anchors).

- Microsoft Learn: Plan your migration from Azure AD B2C to External ID and How to migrate users: migration approaches, custom authentication extensions, just-in-time password migration.
- Azure AD B2C FAQ: end of sale May 1, 2025; P2 discontinued March 15, 2026; support until at least May 2030.